Universidad Técnica Nacional

Sede

San Carlos

Curso:

Calidad del Software

Estudiantes:

Brandon Badilla
Diego Umaña
Francine Barquero

Profesor:

Jose David Carvajal Jimenez

Fecha:

26 de Marzo del 2026

1. Introducción

En el presente laboratorio se realizó el análisis de una aplicación web vulnerable con el objetivo de identificar, explotar y corregir vulnerabilidades de seguridad, principalmente relacionadas con SQL Injection.

Se trabajó en tres etapas fundamentales: exploración de la aplicación, explotación de vulnerabilidades y aplicación de buenas prácticas de seguridad para su corrección.

2. Análisis de Vulnerabilidades

V-01: SQL Injection en Login

Descripción del problema

La consulta SQL del login se construía mediante concatenación directa de strings utilizando los datos ingresados por el usuario, lo que permite manipular la consulta.

Evidencia (Payload utilizado)

```
admin' --
```

Explicación

Este payload comenta la parte de la contraseña, permitiendo ingresar sin validación real.

Por qué es peligrosa

Permite el acceso no autorizado al sistema, comprometiendo la autenticación.

Código vulnerable

```
query = f"SELECT * FROM users WHERE username = '{username}' AND password = '{password}'"
```

Código corregido

```
user = conn.execute(
    "SELECT * FROM users WHERE username = ?",
    (username,)
```

```
).fetchone()

if user and check_password_hash(user["password"], password):
```

V-02: SQL Injection en Búsqueda

Descripción del problema

El término de búsqueda se insertaba directamente en la consulta SQL.

Evidencia (Payload utilizado)

```
%' UNION SELECT id, username, password, role FROM users --
```

Explicación

Permite extraer información de la base de datos (usuarios y contraseñas).

Por qué es peligrosa

Exposición total de datos sensibles del sistema.

Código vulnerable

```
query = f"SELECT * FROM books WHERE title LIKE '%{term}%'"
```

Código corregido

```
like_term = f"%{term}%"
books = conn.execute(
    "SELECT * FROM books WHERE title LIKE ?",
    (like_term,)
).fetchall()
```

V-03: Contraseñas en texto plano

Descripción del problema

Las contraseñas se almacenaban sin cifrado.

Evidencia

Visible en el panel admin.

Por qué es peligrosa

Cualquier acceso a la base de datos expone todas las credenciales.

Código vulnerable

```
("admin", "Admin123", "admin")
```

Código corregido

```
generate_password_hash("Admin123")
```

V-04: SECRET_KEY expuesta

Descripción

La clave secreta estaba definida directamente en el código.

Riesgo

Permite manipular sesiones.

Corrección

```
app.config["SECRET_KEY"] = os.environ.get("SECRET_KEY")
```

V-05: Debug activado

Descripción

El modo debug estaba habilitado.

Riesgo

Permite ejecución de código en el servidor.

Corrección

```
app.run(debug=False)
```

V-06: Consulta SQL expuesta

Descripción

La aplicación mostraba la consulta SQL al usuario.

Riesgo

Facilita ataques de inyección.

Corrección

Se eliminó:

{{ raw_query }}

V-07: Acceso al menú Admin

Descripción

El enlace admin era visible para todos.

Riesgo

Permite intento de acceso no autorizado.

Corrección

{% if session.get('role') == 'admin' %}

V-08: Falta de CSRF

Descripción

Los formularios no tenían protección CSRF.

Riesgo

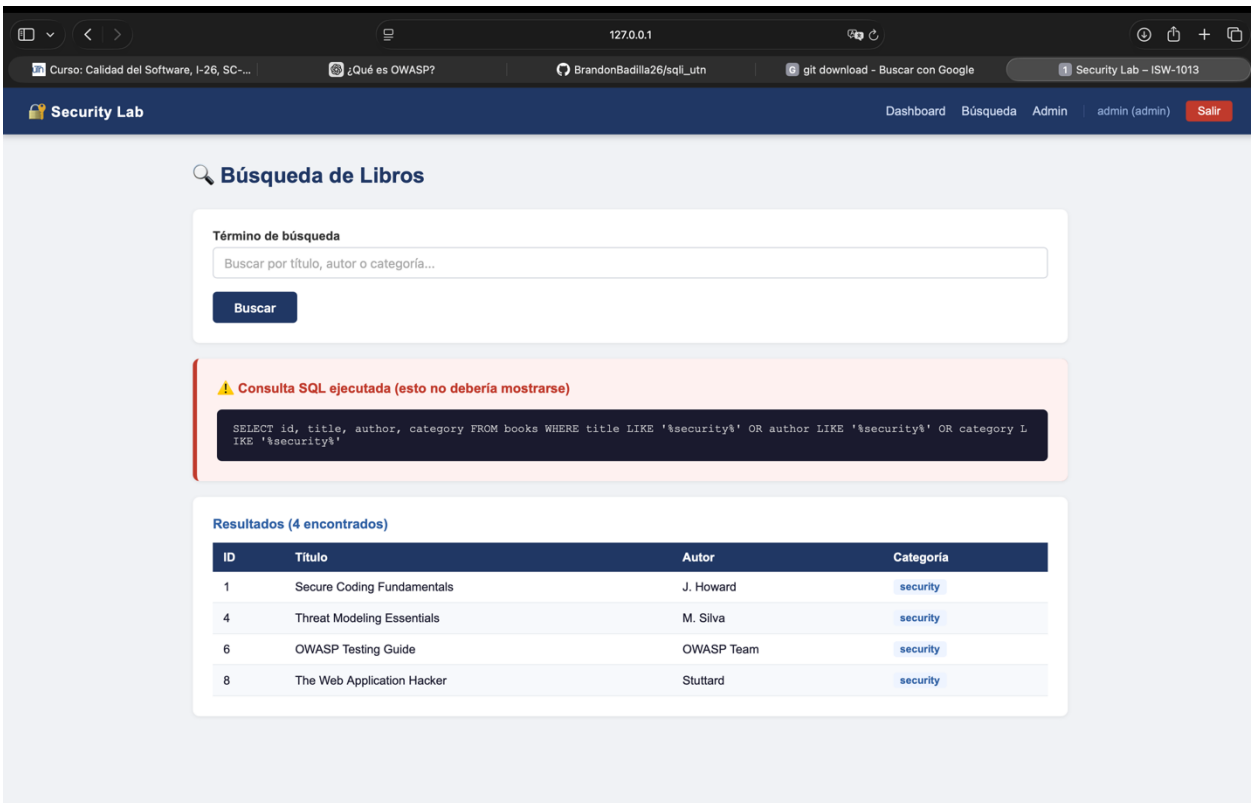
Permite ataques de falsificación de solicitudes.

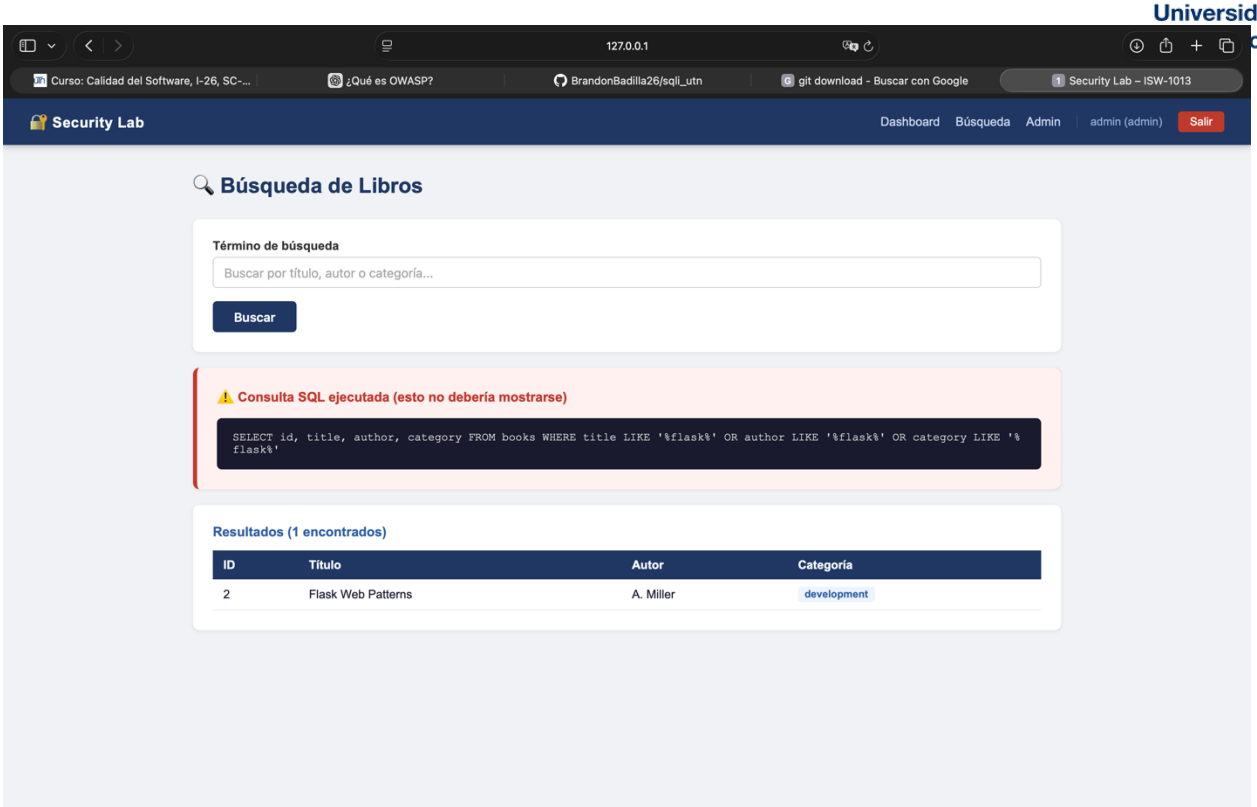
Corrección

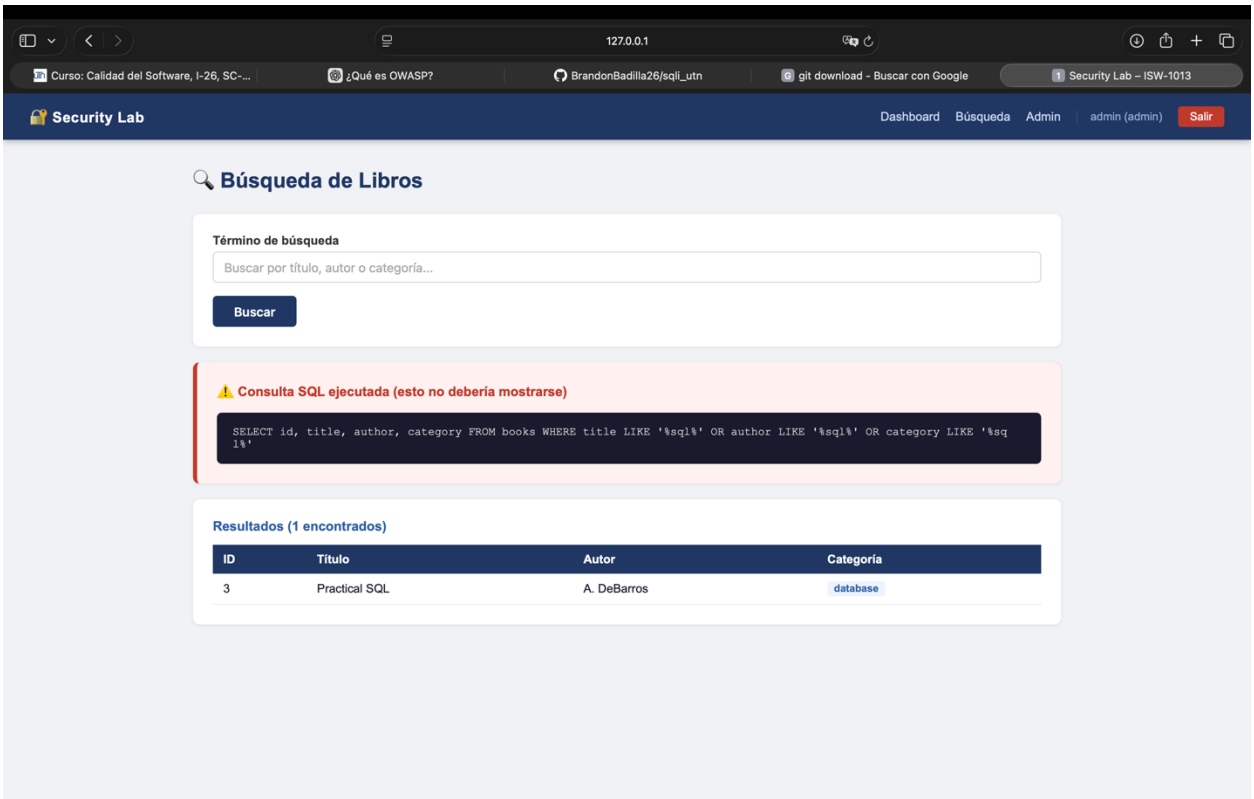
<input type="hidden" name="csrf_token" value="{{ csrf_token() }}">

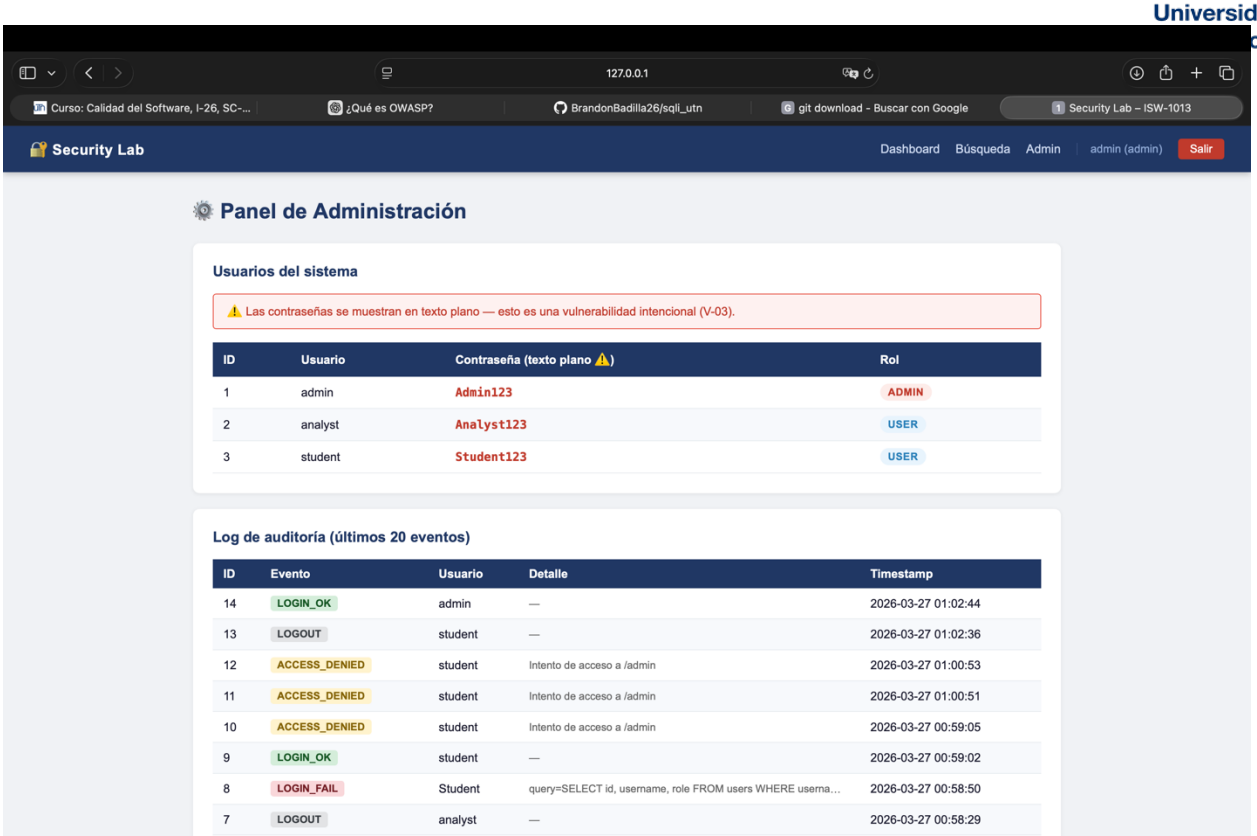
3. Evidencia (Capturas de pantalla)

Admin

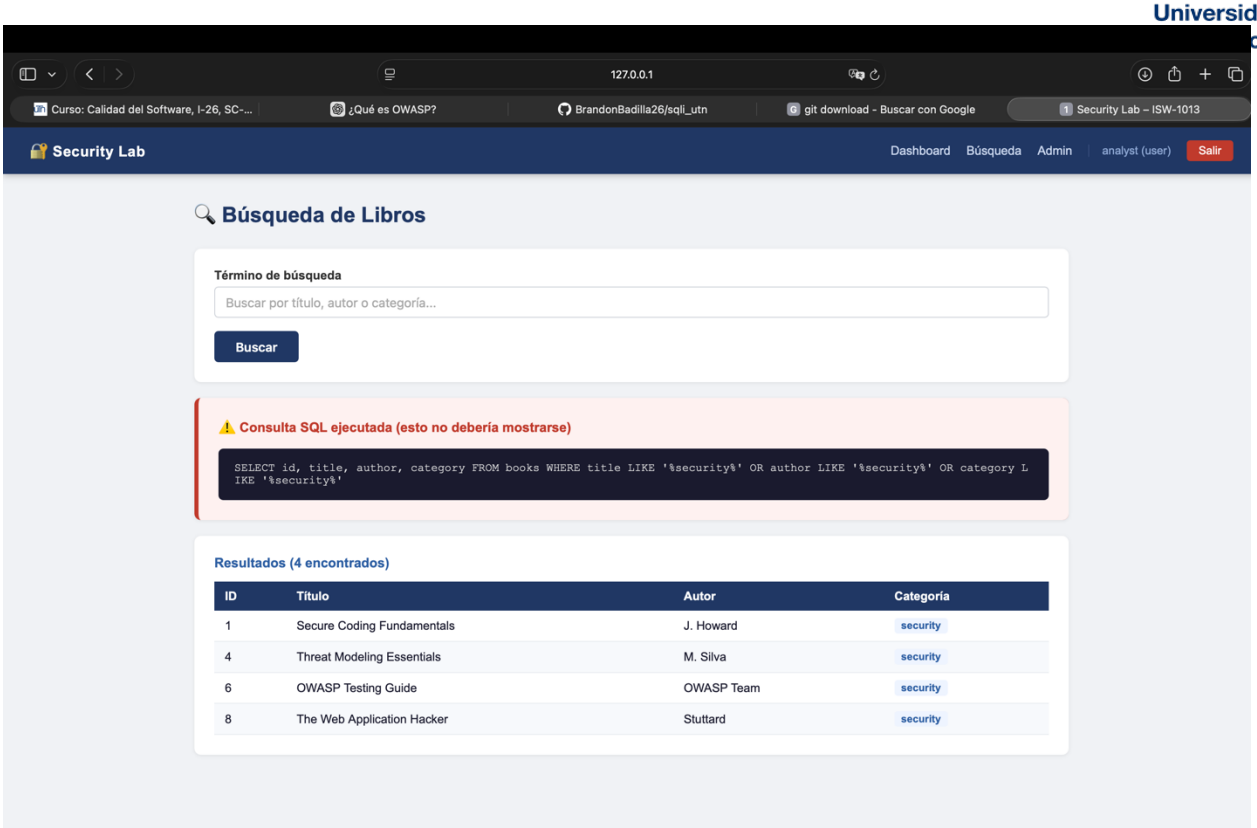


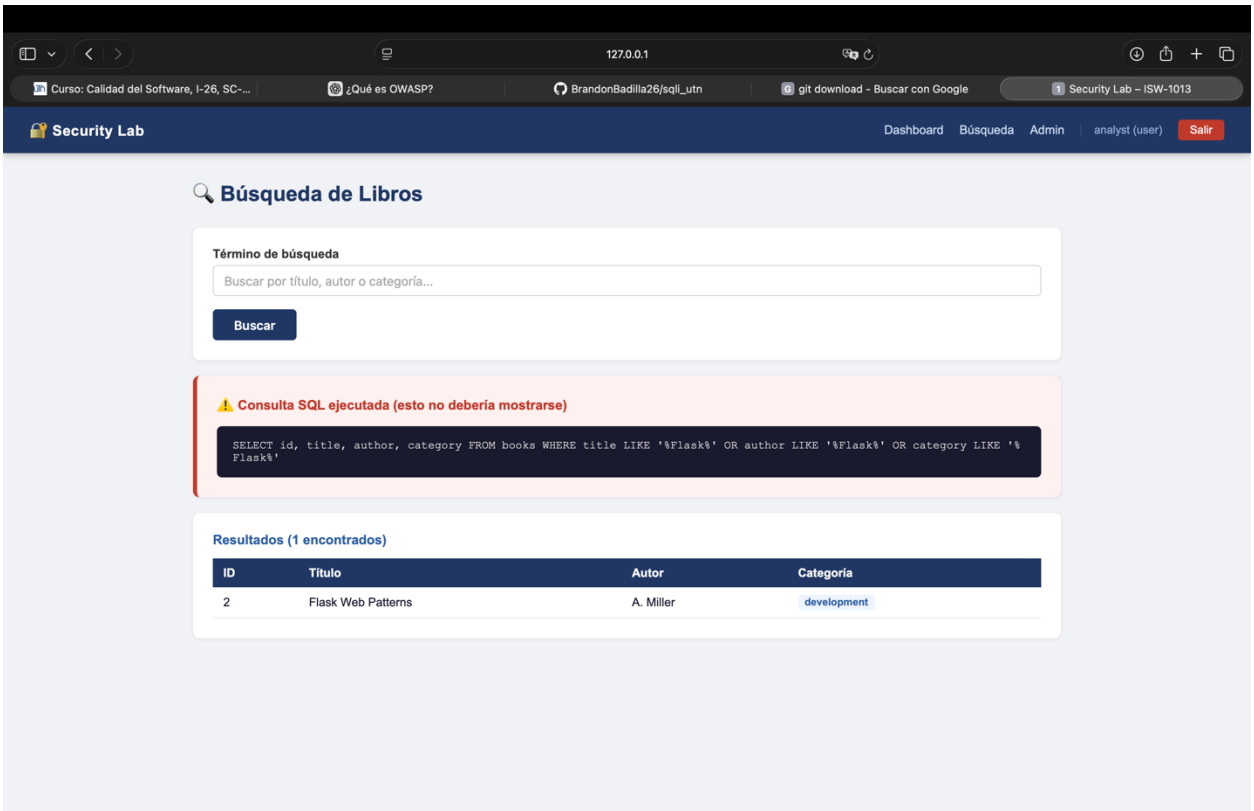

127.0.0.1
Curso: Calidad del Software, I-26, SC-...
¿Qué es OWASP?
BrandonBadilla26/sqli_utn
git download - Buscar con Google
Security Lab – ISW-1013
Security Lab
Dashboard
Búsqueda
Admin
admin (admin)
Salir
Búsqueda de Libros
Término de búsqueda
Buscar por título, autor o categoría...
Buscar
Consulta SQL ejecutada (esto no debería mostrarse)
SELECT id, title, author, category FROM books WHERE title LIKE '%flask%' OR author LIKE '%flask%' OR category LIKE '%flask%'
Resultados (1 encontrados)
ID
Título
Autor
Categoría
2
Flask Web Patterns
A. Miller
development

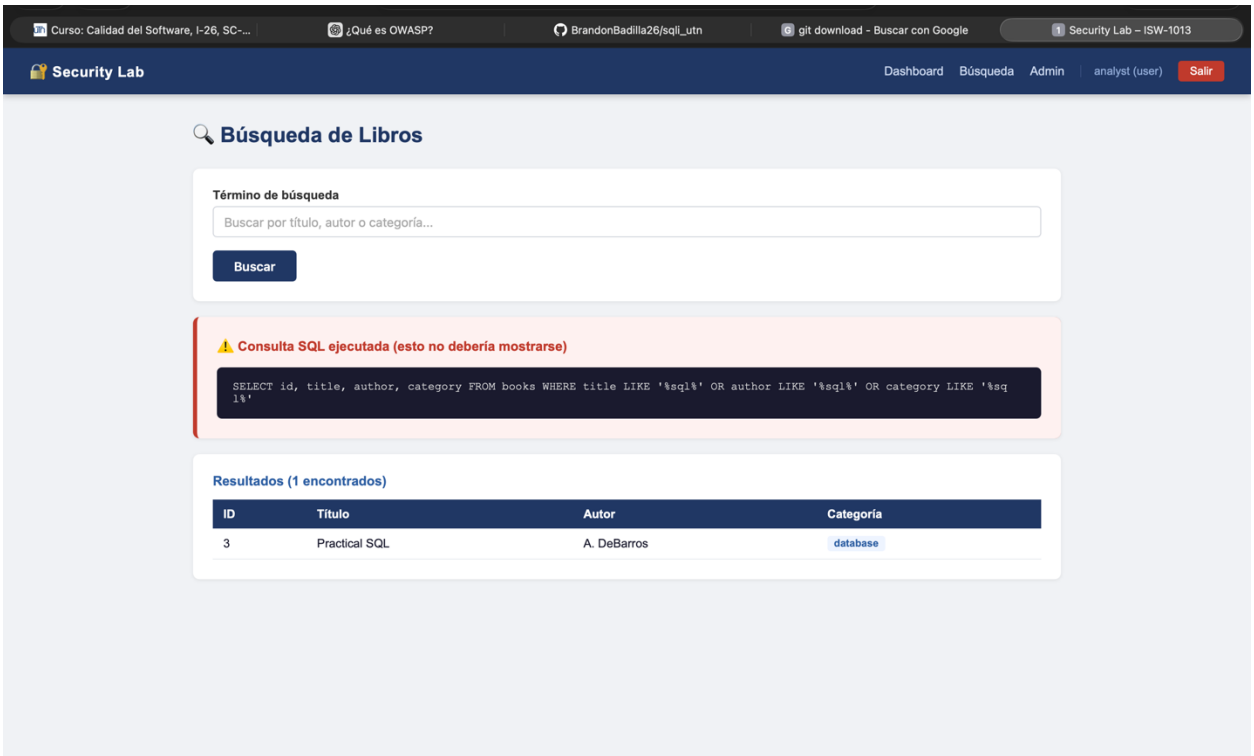

127.0.0.1
Curso: Calidad del Software, I-26, SC-...
¿Qué es OWASP?
BrandonBadilla26/sqli_utn
git download - Buscar con Google
Security Lab – ISW-1013
Security Lab
Dashboard
Búsqueda
Admin
admin (admin)
Salir
Búsqueda de Libros
Término de búsqueda
Buscar por título, autor o categoría...
Buscar
Consulta SQL ejecutada (esto no debería mostrarse)
SELECT id, title, author, category FROM books WHERE title LIKE '%sql%' OR author LIKE '%sql%' OR category LIKE '%sql%'
Resultados (1 encontrados)
ID
Título
Autor
Categoría
3
Practical SQL
A. DeBarros
database


127.0.0.1
Curso: Calidad del Software, I-26, SC-...
¿Qué es OWASP?
BrandonBadilla26/sqli_utn
git download - Buscar con Google
Security Lab – ISW-1013
Security Lab
Dashboard
Búsqueda
Admin
admin (admin)
Salir
Panel de Administración
Usuarios del sistema
Las contraseñas se muestran en texto plano — esto es una vulnerabilidad intencional (V-03).
ID | Usuario | Contraseña (texto plano) | Rol
1 | admin | Admin123 | ADMIN
2 | analyst | Analyst123 | USER
3 | student | Student123 | USER
Log de auditoría (últimos 20 eventos)
ID | Evento | Usuario | Detalle | Timestamp
14 | LOGIN_OK | admin | — | 2026-03-27 01:02:44
13 | LOGOUT | student | — | 2026-03-27 01:02:36
12 | ACCESS_DENIED | student | Intento de acceso a /admin | 2026-03-27 01:00:53
11 | ACCESS_DENIED | student | Intento de acceso a /admin | 2026-03-27 01:00:51
10 | ACCESS_DENIED | student | Intento de acceso a /admin | 2026-03-27 00:59:05
9 | LOGIN_OK | student | — | 2026-03-27 00:59:02
8 | LOGIN_FAIL | Student | query=SELECT id, username, role FROM users WHERE userna... | 2026-03-27 00:58:50
7 | LOGOUT | analyst | — | 2026-03-27 00:58:29

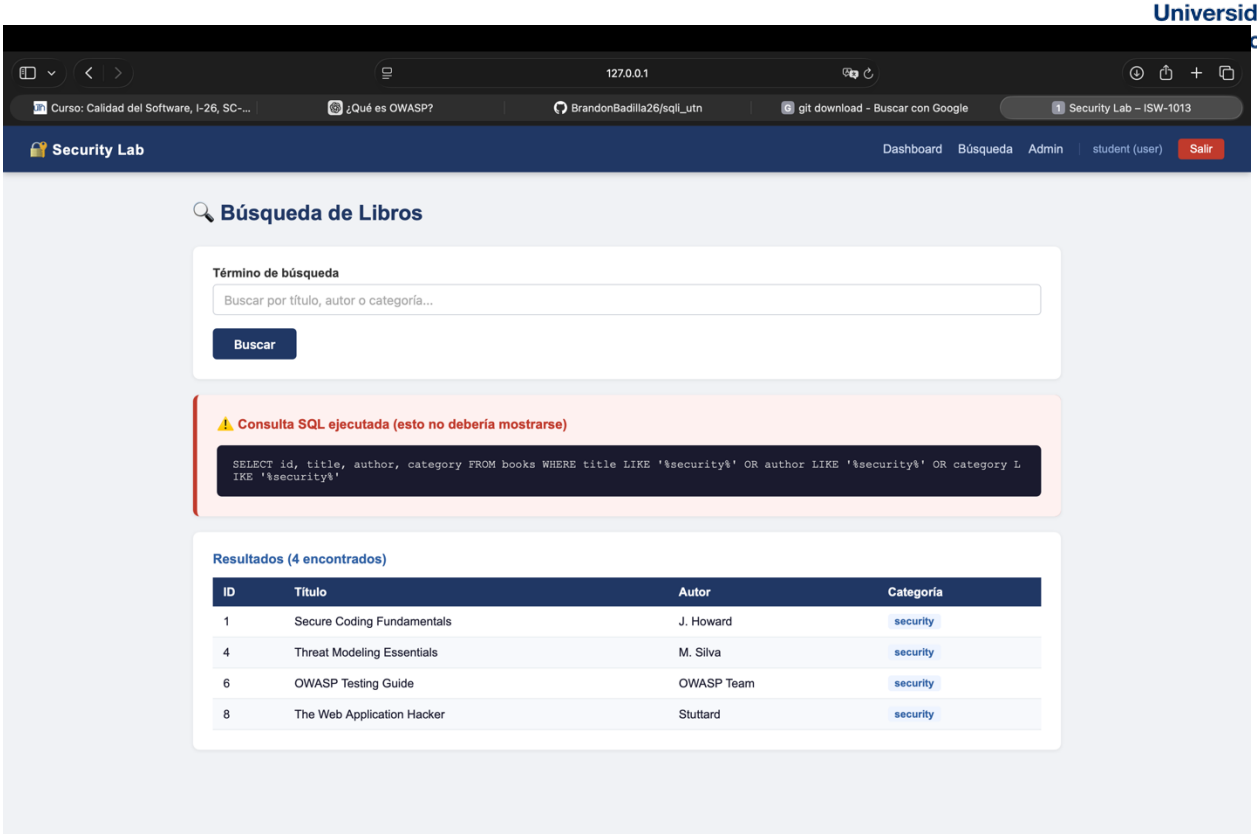
Analyst

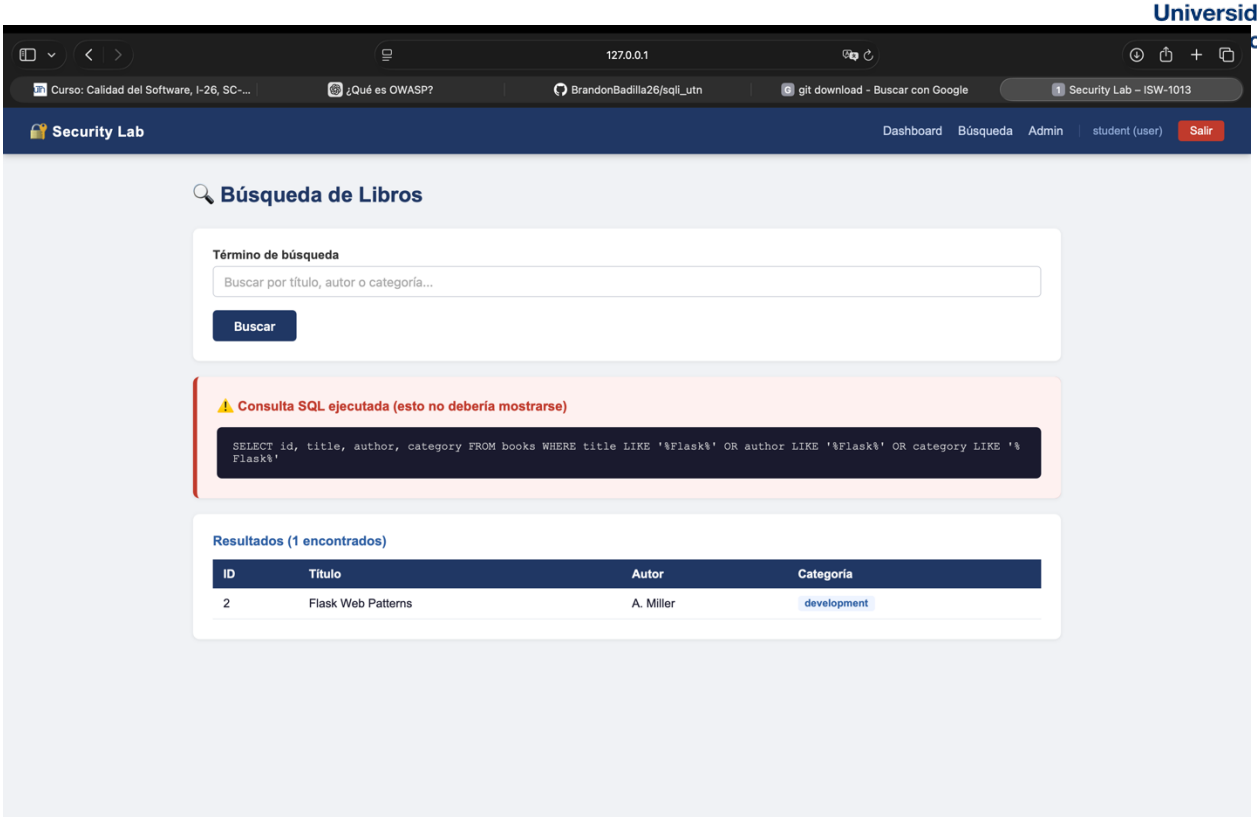

127.0.0.1
Curso: Calidad del Software, I-26, SC-...
¿Qué es OWASP?
BrandonBadilla26/sqli_utn
git download - Buscar con Google
Security Lab – ISW-1013
Security Lab
Dashboard
Búsqueda
Admin
analyst (user)
Salir
Búsqueda de Libros
Término de búsqueda
Buscar por título, autor o categoría...
Buscar
Consulta SQL ejecutada (esto no debería mostrarse)
SELECT id, title, author, category FROM books WHERE title LIKE '%security%' OR author LIKE '%security%' OR category LIKE '%security%'
Resultados (4 encontrados)
ID
Título
Autor
Categoría
1
Secure Coding Fundamentals
J. Howard
security
4
Threat Modeling Essentials
M. Silva
security
6
OWASP Testing Guide
OWASP Team
security
8
The Web Application Hacker
Stuttard
security

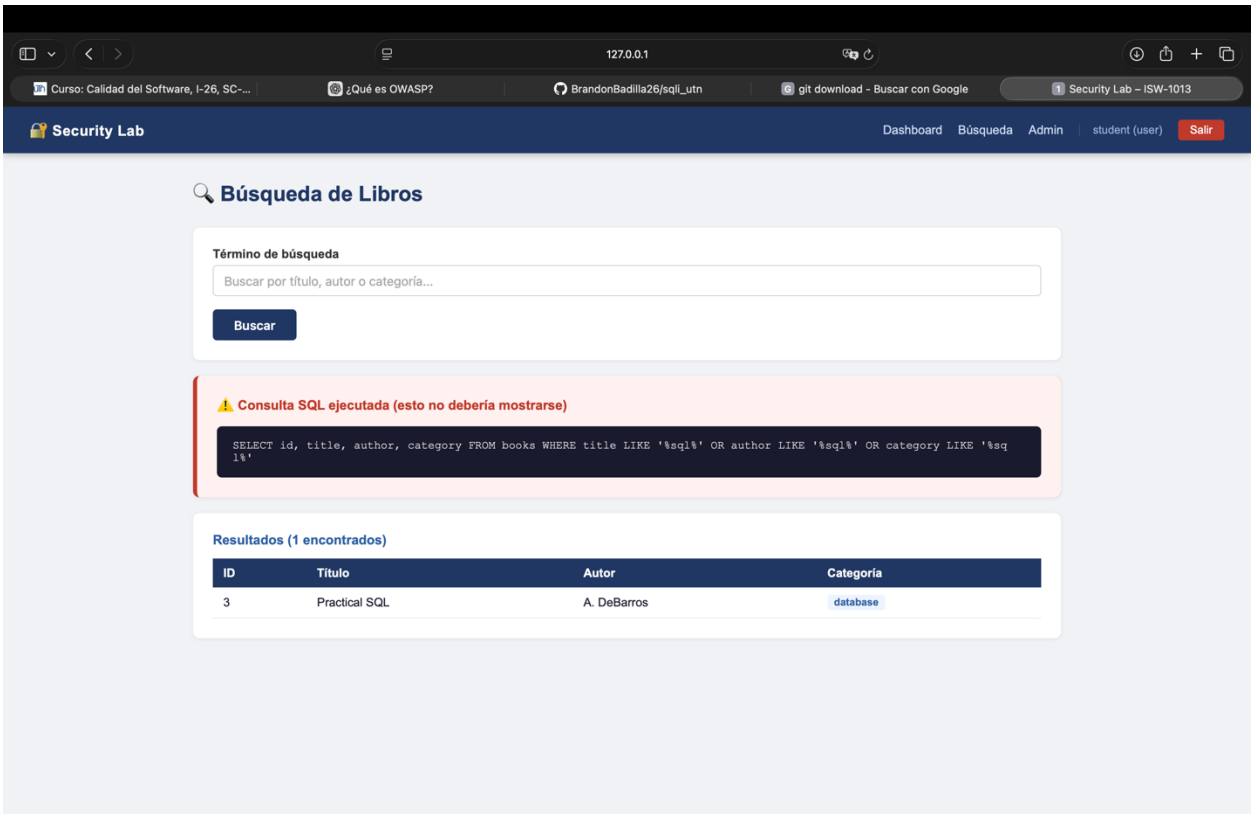

127.0.0.1
Curso: Calidad del Software, I-26, SC-...
¿Qué es OWASP?
BrandonBadilla26/sqli_utn
git download - Buscar con Google
Security Lab – ISW-1013
Security Lab
Dashboard
Búsqueda
Admin
analyst (user)
Salir
Búsqueda de Libros
Término de búsqueda
Buscar por título, autor o categoría...
Buscar
Consulta SQL ejecutada (esto no debería mostrarse)
SELECT id, title, author, category FROM books WHERE title LIKE '%Flask%' OR author LIKE '%Flask%' OR category LIKE '%Flask%'
Resultados (1 encontrados)
ID
Título
Autor
Categoría
2
Flask Web Patterns
A. Miller
development


Curso: Calidad del Software, I-26, SC-...
¿Qué es OWASP?
BrandonBadilla26/sqli_utn
git download - Buscar con Google
Security Lab – ISW-1013
Security Lab
Dashboard
Búsqueda
Admin
analyst (user)
Salir
Búsqueda de Libros
Término de búsqueda
Buscar por título, autor o categoría...
Buscar
Consulta SQL ejecutada (esto no debería mostrarse)
SELECT id, title, author, category FROM books WHERE title LIKE '%sql%' OR author LIKE '%sql%' OR category LIKE '%sq
l%'
Resultados (1 encontrados)
ID
Título
Autor
Categoría
3
Practical SQL
A. DeBarros
database

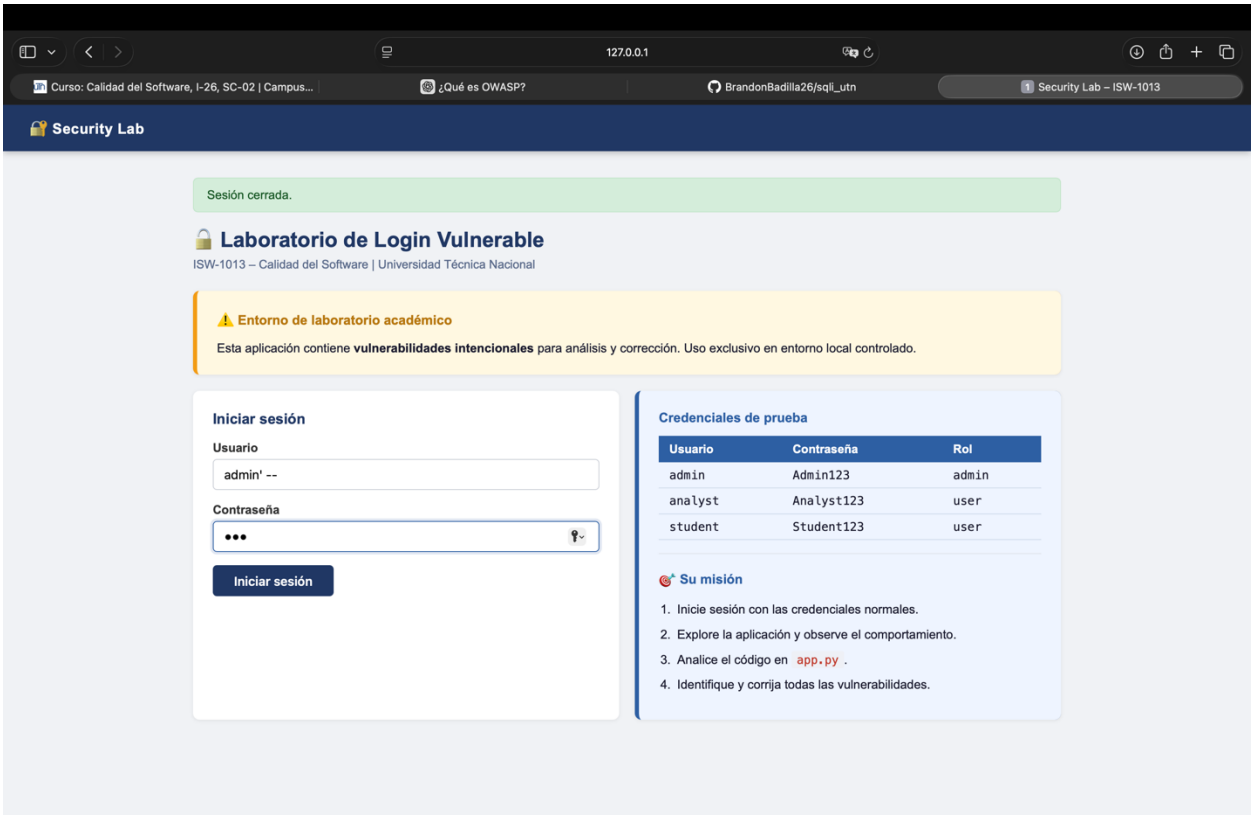
Student

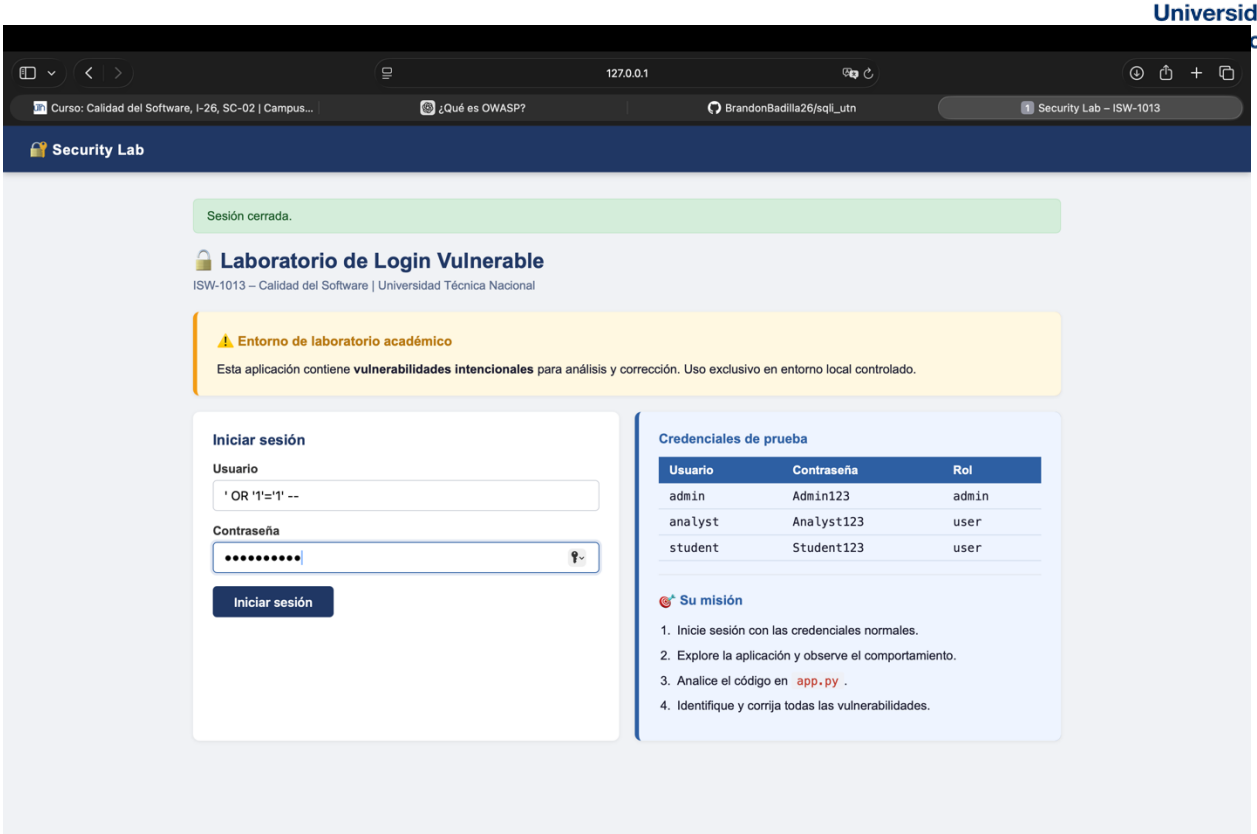

127.0.0.1
Curso: Calidad del Software, I-26, SC-...
¿Qué es OWASP?
BrandonBadilla26/sqli_utn
git download - Buscar con Google
Security Lab – ISW-1013
Security Lab
Dashboard
Búsqueda
Admin
student (user)
Salir
Búsqueda de Libros
Término de búsqueda
Buscar por título, autor o categoría...
Buscar
Consulta SQL ejecutada (esto no debería mostrarse)
SELECT id, title, author, category FROM books WHERE title LIKE '%security%' OR author LIKE '%security%' OR category L
IKE '%security%'
Resultados (4 encontrados)
ID
Título
Autor
Categoría
1
Secure Coding Fundamentals
J. Howard
security
4
Threat Modeling Essentials
M. Silva
security
6
OWASP Testing Guide
OWASP Team
security
8
The Web Application Hacker
Stuttard
security

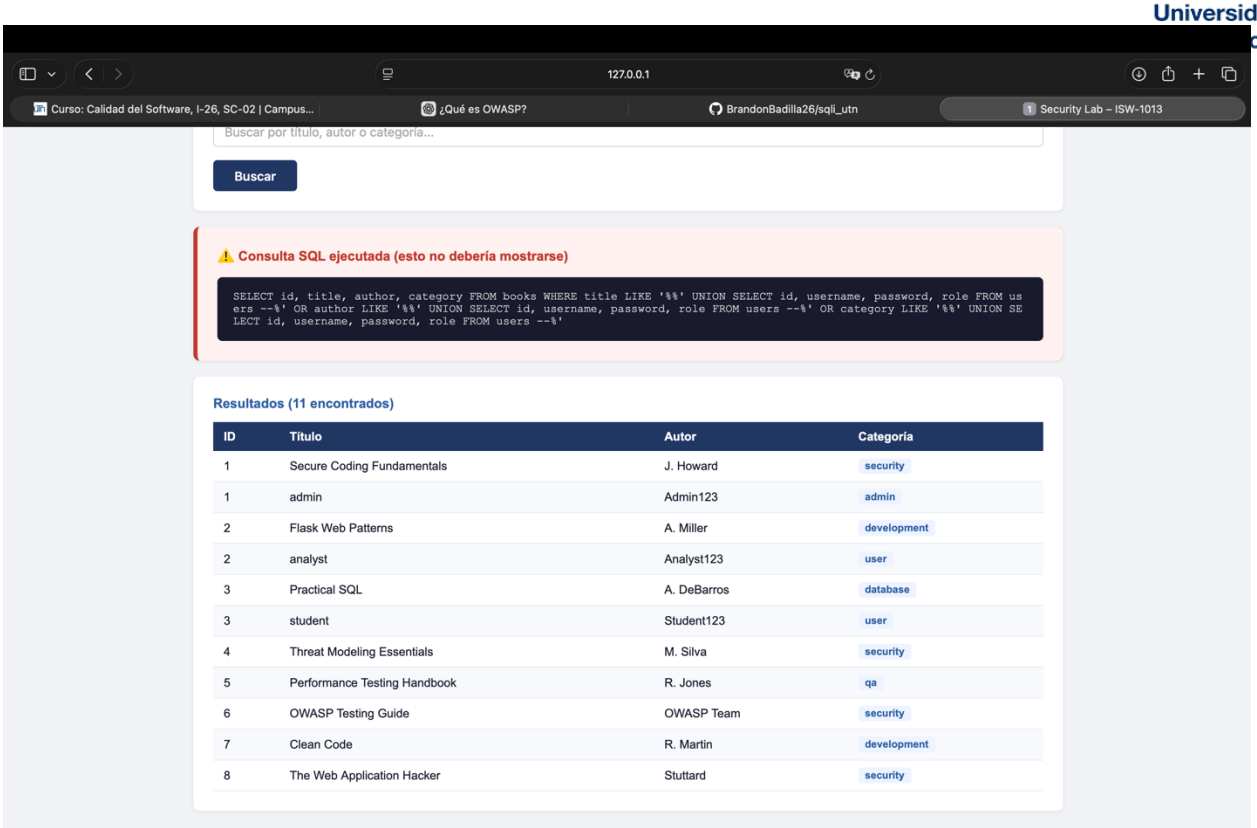

127.0.0.1
Curso: Calidad del Software, I-26, SC-...
¿Qué es OWASP?
BrandonBadilla26/sqli_utn
git download - Buscar con Google
Security Lab – ISW-1013
Security Lab
Dashboard
Búsqueda
Admin
student (user)
Salir
Búsqueda de Libros
Término de búsqueda
Buscar por título, autor o categoría...
Buscar
Consulta SQL ejecutada (esto no debería mostrarse)
SELECT id, title, author, category FROM books WHERE title LIKE '%Flask%' OR author LIKE '%Flask%' OR category LIKE '%Flask%'
Resultados (1 encontrados)
ID
Título
Autor
Categoría
2
Flask Web Patterns
A. Miller
development


127.0.0.1
Curso: Calidad del Software, I-26, SC-...
¿Qué es OWASP?
BrandonBadilla26/sqli_utn
git download - Buscar con Google
Security Lab – ISW-1013
Security Lab
Dashboard
Búsqueda
Admin
student (user)
Salir
Búsqueda de Libros
Término de búsqueda
Buscar por título, autor o categoría...
Buscar
Consulta SQL ejecutada (esto no debería mostrarse)
SELECT id, title, author, category FROM books WHERE title LIKE '%sql%' OR author LIKE '%sql%' OR category LIKE '%sql%'
Resultados (1 encontrados)
ID
Título
Autor
Categoría
3
Practical SQL
A. DeBarros
database

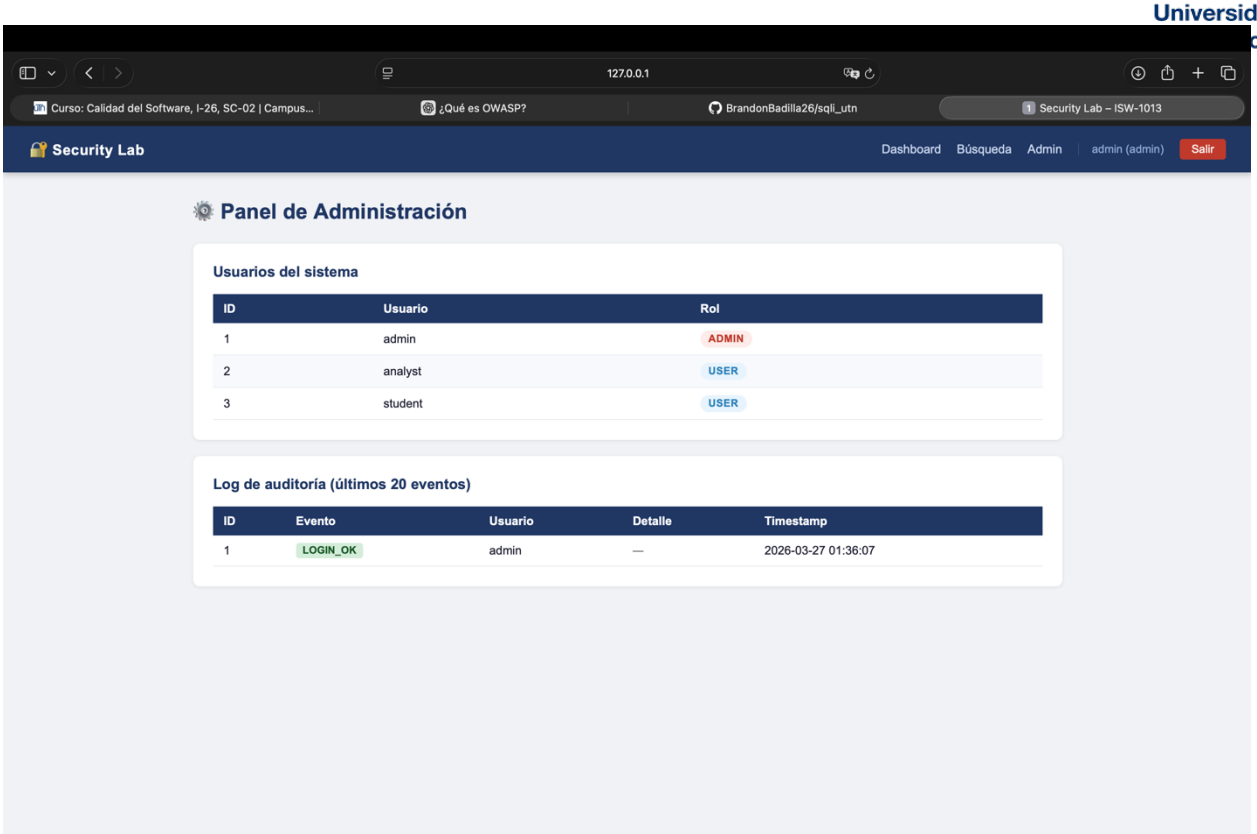
Vulnerabilidades




127.0.0.1
Curso: Calidad del Software, I-26, SC-02 | Campus...
¿Qué es OWASP?
BrandonBadilla26/sqli_utn
Security Lab – ISW-1013
Security Lab
Sesión cerrada.
Laboratorio de Login Vulnerable
ISW-1013 – Calidad del Software | Universidad Técnica Nacional
Entorno de laboratorio académico
Esta aplicación contiene vulnerabilidades intencionales para análisis y corrección. Uso exclusivo en entorno local controlado.
Iniciar sesión
Usuario
' OR '1'='1' --
Contraseña
Iniciar sesión
Credenciales de prueba
Usuario Contraseña Rol
admin Admin123 admin
analyst Analyst123 user
student Student123 user
Su misión
1. Inicie sesión con las credenciales normales.
2. Explore la aplicación y observe el comportamiento.
3. Analice el código en app.py .
4. Identifique y corrija todas las vulnerabilidades.



Correcciones



4. Conclusiones

Durante el desarrollo de este laboratorio se logró comprender de manera práctica el impacto real de las vulnerabilidades de seguridad en aplicaciones web.

Se evidenció que la SQL Injection es una de las vulnerabilidades más críticas, ya que permite desde el acceso no autorizado hasta la extracción completa de la base de datos.

La parte más compleja del laboratorio fue la implementación correcta de las medidas de seguridad, especialmente el uso de consultas parametrizadas y el manejo de hashing de contraseñas.

La vulnerabilidad más crítica identificada fue la del login (SQL Injection), debido a que comprometía directamente el acceso al sistema sin necesidad de credenciales válidas.

Este laboratorio permitió reforzar la importancia de aplicar buenas prácticas desde el desarrollo inicial y no como una etapa posterior.

5. Conclusión final

El uso de herramientas como Docker, Git y técnicas de seguridad permitió comprender el ciclo completo de detección, explotación y mitigación de vulnerabilidades, fortaleciendo las competencias en desarrollo seguro.